WHY OAUTH ISN'T USUALLY ENOUGH

In mid-2025, Google disclosed (https://cloud.google.com/blog/topics/threat-intelligence/data-theft-salesforce-instances-via-salesloft-drift?utm_source=chatgpt.com) that attackers had gained unauthorized access to internal systems by reusing OAuth bearer tokens stolen from a third-party vendor's Salesforce integration. The tokens, originally issued for an AI customer-support platform, remained valid and carried broad scopes that allowed the attackers to access connected Google Workspace and cloud resources. Since OAuth treats possession of a valid token as sufficient proof of authorization, the attackers never needed passwords or user credentials.

The breach highlighted an important lesson: OAuth handles delegation, not decision-making. Scopes specify which APIs a client can attempt to call, but they do not decide whether a certain action on a specific resource should be permitted. Without a policy layer that enforces detailed rules—such as per-resource permissions, context validation, and short token lifetimes—a stolen token can serve as an all-access pass until it expires or is revoked.

Using fine-grained authorization systems can reduce that blast radius. Scopes should specify only the outer boundary of access ("this app can call the documents API"). Beyond that, policies must control each individual request ("this principal may read metadata on documents they own, but not documents marked Legal"). With short-lived tokens, ongoing evaluation, and Cedar-style policy enforcement, the compromise of a single token does not automatically grant broad or permanent access.

The Salesforce breach serves as a clear reminder: OAuth addresses the delegation issue, but by itself, it does not provide a full authorization system.